DOCUMENT CONTROL PAGE

Field	Details
Document Title	Information Security Policy
Document ID	CIL-GRC-STRAT-2026-001
Version	1.0
Effective Date	01 March 2026
Review Date	01 March 2027
Policy Domain	ISO/IEC 27002:2022 –Domain 5 (Organizational Controls)
Control Reference/Sub-Domain	5.1 – Policies for Information Security
Policy Owner	Chief Information Security Officer (CISO)
Policy Author	GRC Manager
Reviewer	Managing Director
Classification	Confidential - Internal Use Only
Distribution	All Employees, Contractors, Third Parties (where applicable)
Supercedes	New Document

APPROVED BY
Managing Director (CEO)

_____

For: Cyberinfiniti Ltd

Information Security Policy Summary

1. Overview and Purpose

The Information Security Policy establishes the formal governance framework for managing and protecting information assets within Cyberinfiniti Ltd. It defines management direction, strategic objectives, and organisational commitment to safeguarding sensitive information in alignment with international standards such as ISO/IEC 27002:2022, regulatory requirements including Nigeria Data Protection Act 2023, and applicable contractual obligations.

The policy is designed to ensure the **confidentiality, integrity, and availability (CIA)** of information assets while supporting business continuity and operational resilience. It also ensures that information security practices remain appropriate, effective, and continuously improved in response to evolving risks and regulatory expectations.

2. Scope and Definition of Information Security

The policy applies to:

- All employees, contractors, and consultants
- Third-party service providers
- All organisational information assets
- All systems, networks, devices, and cloud environments

Information security within this context is defined by the protection of:

- **Confidentiality** – preventing unauthorized access to information
- **Integrity** – ensuring accuracy and completeness of data
- **Availability** – ensuring reliable access to systems and information when needed

These principles guide all security controls and decision-making processes within the organisation.

3. Roles and Responsibilities

Effective governance requires clear accountability across all levels:

- **Managing Director** – Provides executive oversight and approves policies
- **Chief Information Security Officer (CISO)** – Owns the policy and leads security strategy
- **GRC Manager** – Develops policies and monitors compliance
- **SOC Manager** – Oversees operational security monitoring and response
- **IAM Specialist** – Manages identity and access controls
- **IT Operations Lead** – Ensures infrastructure security
- **All Employees** – Responsible for adhering to policy requirements

This structured assignment of roles ensures accountability, segregation of duties, and effective control implementation.

4. Governance and Policy Framework

In alignment with ISO/IEC 27002:2022 Control 5.1, the organisation adopts a structured governance approach based on the following principles:

4.1 Management Commitment

Top management provides visible leadership and support for information security initiatives, ensuring adequate resources and strategic direction.

4.2 Risk-Based Approach

Security controls are implemented based on formal risk assessments, ensuring that resources are prioritised according to actual risk exposure.

4.3 Regulatory and Legal Compliance

The organisation ensures compliance with all applicable laws, regulations, and contractual obligations, including Nigeria Data Protection Act 2023.

4.4 Supporting Policies

This policy is supported by a suite of **topic-specific policies**, including:

- Access Control Policy
- Incident Management Policy
- Information Classification Policy
- Vulnerability Management Policy
- Business Continuity Policy
- AI Governance Policy

4.5 Assignment of Responsibilities

Information security responsibilities are clearly defined and assigned to appropriate roles across the organisation.

4.6 Continual Improvement

The ISMS is continuously improved through:

- Audit findings
- Risk assessments
- Incident analysis

- Regulatory updates
- Management reviews

4.7 Exception Management

All deviations from policy must be:

- Documented
- Risk assessed
- Approved by the CISO
- Periodically reviewed.

5. Monitoring, Compliance, and Enforcement

Compliance with this policy is actively monitored through:

- Internal audits
- Access and control reviews
- Incident reporting and trend analysis
- Risk assessments
- Executive-level reporting

Failure to comply may result in:

- Disciplinary action for employees
- Contract termination for third parties
- Legal consequences where applicable

This ensures that the policy is not only defined but also **enforced and measurable**.

6. Policy Review

To remain effective and relevant, the policy is subject to:

- Annual review
- Updates following significant business or technological changes
- Revisions after major security incidents
- Adjustments based on regulatory developments

The review process considers:

- Audit results
- Management review outputs
- Emerging threats
- Lessons learned from incidents

7. Communication and Awareness

The policy is communicated across the organisation through:

- Internal governance platforms
- Employee onboarding programs
- Regular training and awareness sessions

All personnel are required to:

- Acknowledge the policy
- Confirm understanding
- Comply with its requirements

This ensures organisation-wide awareness and accountability.

8. Continual Improvement Commitment

Cyberinfiniti Ltd is committed to maintaining a dynamic and evolving Information Security Management System that adapts to:

- Business growth and operational changes
- Technological advancements
- Regulatory developments
- Emerging cyber threats

This commitment ensures that information security remains resilient, effective, and aligned with industry best practices, particularly ISO/IEC 27002:2022.

Conclusion

This Information Security Policy provides a comprehensive governance framework for protecting information assets within Cyberinfiniti Ltd. By aligning with international standards, regulatory requirements, and industry best practices, the organisation ensures a structured, risk-based, and continuously improving approach to information security.

1. PURPOSE

The purpose of this Information Security Policy is to establish the formal governance framework for managing information security within Cyberinfiniti Ltd.

This policy defines management direction, strategic objectives, and organizational commitment to safeguarding information assets in accordance with:

- ISO/IEC 27002:2022
- Nigeria Data Protection Act (NDPA) 2023
- Contractual security obligations
- Business continuity requirements
- Industry best practices

This policy ensures the continuing suitability, adequacy, and effectiveness of information security governance across the organization.

---

2. ORGANIZATIONAL CONTEXT

Cyberinfiniti Ltd is a cybersecurity services organization delivering:

- Security Operations Center (SOC) services
- Vulnerability Assessment & Penetration Testing
- Cloud security advisory
- Governance, Risk & Compliance consulting
- Security training and awareness

As a cybersecurity startup firm hoping to achieve a mature security organization model, Cyberinfiniti handles:

- Client security configurations
- Threat intelligence data
- Sensitive vulnerability findings
- Compliance documentation
- Personal data subject to NDPA

The compromise of these assets could result in:

- Regulatory sanctions
- Financial penalties
- Contractual liability

- Reputational damage
- Loss of client trust

This policy establishes executive-level governance to manage these risks.

---

3. SCOPE

This policy applies to:

- All employees
- All contractors and consultants
- All third-party service providers
- All information assets owned, processed, or managed by Cyberinfiniti Ltd
- All information systems, networks, devices, and cloud services

---

4. DEFINITION OF INFORMATION SECURITY

Information security is defined as the preservation of:

- Confidentiality – Ensuring information is accessible only to authorized individuals
- Integrity – Safeguarding accuracy and completeness of information
- Availability – Ensuring reliable and timely access to information

---

5. INFORMATION SECURITY OBJECTIVES

Cyberinfiniti Ltd establishes the following high-level security objectives:

1. Protect client and organizational data from unauthorized disclosure.
2. Maintain integrity of security assessment and investigative outputs.
3. Ensure availability of critical systems supporting service delivery.
4. Achieve regulatory compliance with NDPA 2023.

5. Strengthen resilience against cyber threats.
6. Continuously improve the Information Security Management System (ISMS).

Security objectives shall be reviewed annually by executive management.

---

6. POLICY STATEMENTS

In alignment with ISO/IEC 27002:2022 Control 5.1, Cyberinfiniti Ltd commits to:

6.1 Governance Commitment

Top management shall provide visible leadership and support for information security initiatives.

6.2 Risk-Based Approach

Information security controls shall be implemented based on formal risk assessment.

6.3 Regulatory & Legal Compliance

Cyberinfiniti Ltd shall comply with applicable laws, including NDPA 2023, and contractual security requirements.

6.4 Topic-Specific Policies

This Information Security Policy shall be supported by topic-specific policies including but not limited to:

- Access Control Policy
- Incident Management Policy
- Information Classification Policy
- Vulnerability Management Policy
- Business Continuity Policy
- AI Governance Policy

6.5 Assignment of Responsibilities

Information security responsibilities shall be formally assigned to defined roles.

6.6 Continual Improvement

The ISMS shall be continuously reviewed and improved based on:

- Audit findings
- Risk assessments
- Security incidents
- Regulatory changes
- Management reviews

6.7 Exception Management

All policy exceptions must:

- Be documented
- Undergo risk assessment
- Be approved by the CISO
- Be reviewed periodically

---

7. ROLES AND RESPONSIBILITIES

Role	Responsibility
Managing Director	Executive oversight and approval
Chief Information Security Officer (CISO)	Policy ownership and strategic implementation
GRC Manager	Policy development and compliance monitoring
SOC Manager	Operational enforcement
IAM Specialist	Identity and access governance
IT Operations Lead	Infrastructure security enforcement
All Employees	Policy compliance

---

8. POLICY REVIEW AND MAINTENANCE

This policy shall be:

- Reviewed annually
- Reviewed upon significant changes to business operations
- Updated following major security incidents
- Updated when regulatory requirements change

The review process shall consider:

- Audit findings
- Management review outcomes
- Emerging threat landscape
- Lessons learned from incidents

---

9. COMMUNICATION & ACKNOWLEDGEMENT

This policy shall be:

- Published on the internal governance portal
- Communicated to all employees
- Included in onboarding training
- Subject to mandatory annual acknowledgement

Employees must formally acknowledge understanding and compliance.

---

10. MONITORING & COMPLIANCE

Compliance shall be monitored through:

- Internal audits
- Access reviews
- Incident trend reporting
- Risk assessments
- Executive governance reporting

Non-compliance may result in:

- Disciplinary action
- Contract termination (for third parties)
- Legal consequences

---

11. CONTINUAL IMPROVEMENT COMMITMENT

Cyberinfiniti Ltd commits to maintaining an effective Information Security Management System that evolves with:

- Business growth
- Technological change
- Regulatory development
- Threat landscape evolution